



# Identidad de handle en el AT Protocol

De Auth0 al inicio de sesión descentralizado en Aesthetic Computer

ATProto OAuth, verificación de handles e identidad creativa port til

@jeffrey

Aesthetic.Computer

ORCID: 0009-0007-4460-4913

<https://aesthetic.computer>

[ borrador de trabajo — no citar ]

**Resumen.** Aesthetic Computer actualmente autentica a los usuarios a través de Auth0 y mantiene una identidad paralela en un Personal Data Server (PDS) autoalojado del AT Protocol en `at.aesthetic.computer`. Cada usuario verificado recibe un DID y un handle en el PDS, pero la autenticación pasa por un proveedor OAuth centralizado. Proponemos colapsar esta arquitectura de identidad dual adoptando AT Protocol OAuth [Bluesky PBC, 2024d] como método principal de inicio de sesión, permitiendo que cualquier persona con una identidad de Bluesky o ATProto se autentique directamente y reclame el handle equivalente en Aesthetic Computer. Este artículo revisa la pila de identidad de AT Protocol—DIDs, verificación de handles, OAuth 2.1 con DPoP y PAR—examina cómo `pckt.blog` y otras aplicaciones nativas de ATProto implementan el inicio de sesión descentralizado [pckt.blog, 2025], mapea la arquitectura de autenticación actual de AC y propone una migración por fases desde la dependencia de Auth0 hacia una identidad AT Protocol-first. El argumento central: en una plataforma que ya ejecuta su propio PDS y acuña sus propios DIDs, el proveedor de identidad centralizado es el órgano vestigial. Eliminarlo simplifica la pila, elimina una dependencia de pago y convierte a AC en un ciudadano de primera clase de la web social federada.

## 1. INTRODUCCIÓN

La identidad en la web es un problema de arrendador. No eres dueño de tu handle en Twitter, tu nombre de usuario en Instagram ni tu inicio de sesión en ninguna plataforma que pueda eliminar tu cuenta. El AT Protocol [Bluesky PBC, 2024e]—el protocolo de red social descentralizada detrás de Bluesky—propone un arreglo diferente: tu identidad es un par de claves criptográficas, tu handle es un nombre de dominio que tú controlas, y tus datos viven en un Personal Data Server que puedes mover entre proveedores.

Aesthetic Computer ha operado un sistema de identidad híbrido desde 2024. Auth0 [Auth0 by Okta, 2024] gestiona la autenticación: OAuth 2.0 con PKCE, refresh tokens y una base de datos de usuarios administrada. Por separado, un PDS autoalojado en `at.aesthetic.computer` acuña identidades ATProto para cada usuario verificado. El resultado es un sistema duplicado: dos identidades por usuario, dos almacenes de credenciales, dos rutas de sincronización de handles y una suscripción de pago a Auth0 que cubre la brecha.

Este artículo pregunta: ¿y si el PDS es el proveedor de identidad?

La respuesta no es hipotética. `pckt.blog` [pckt.blog, 2025], una plataforma de blogging construida sobre AT Protocol, autentica a los usuarios exclusivamente a través de AT Protocol OAuth. Los usuarios inician sesión con su handle de Bluesky, su PDS autoalojado o cualquier proveedor de identidad compatible. Sin Auth0, sin Firebase, sin base de datos de usuarios centralizada. El contenido se sincroniza con el PDS del propio usuario utilizando lexicons compartidos de Standard.site [Standard.site, 2025].

Examinamos cómo este modelo se aplica a Aesthetic Computer—una plataforma de computación creativa con más de 600 piezas interactivas, sesiones multijugador, un lenguaje de programación KidLisp y un sistema operativo nativo bare-metal [jeffrey, 2026]—y proponemos una migración por fases que preserva la compatibilidad hacia atrás mientras avanza hacia la identidad descentralizada.

## 2. ARQUITECTURA ACTUAL

### 2.1 Auth0 como proveedor de identidad

La autenticación fluye a través del SDK SPA de Auth0. Al cargar la página, `boot.mjs` verifica `localStorage` en

busca de estado Auth0 en caché. Si existe una sesión (o se detecta un callback OAuth), inicializa el cliente Auth0 con PKCE y refresh tokens, intercambia códigos de autorización por access tokens y recupera el perfil del usuario. El campo sub de Auth0 (p. ej., auth0|abc123 o google-oauth2|xyz) sirve como identificador interno del usuario.

```
// boot.mjs: current Auth0 flow
const auth0 = await createAuth0Client({
  domain: "hi.aesthetic.computer",
  clientId: "LVdZaM...",
  cacheLocation: "localStorage",
  useRefreshTokens: true,
});
const user = await auth0.getUser();
// { sub, email, email_verified, ... }
```

## 2.2 Sistema de handles

Los handles se almacenan en una colección MongoDB @handles, que mapea el sub de Auth0 a una cadena alfanumérica de 1–16 caracteres (con . y \_ permitidos). La validación impone que no haya puntuación inicial/final, unicidad insensible a mayúsculas y filtrado de contenido ofensivo. Los handles son la identidad principal orientada al usuario: direccionables por URL (@handle/piece-name), visibles en el chat y pronunciados por AC Native OS.

## 2.3 Identidad sombra ATProto

En la primera verificación de correo electrónico, un webhook de Auth0 activa createAtprotoAccount(), que:

1. Genera una contraseña de 32 caracteres
2. Crea un código de invitación en el PDS
3. Crea una cuenta en handle.at.aesthetic.computer
4. Almacena el DID, el handle y la contraseña cifrada en MongoDB (users.atproto)

Cuando un usuario cambia su handle de AC, updateAtprotoHandle() sincroniza el cambio con el PDS. El contenido (pinturas, estados de ánimo, fragmentos de KidLisp, cintas, noticias) se replica en el PDS a través de seis lexicons personalizados (computer.aesthetic.\*). La identidad ATProto es real y funcional—pero el usuario nunca se autentica a través de ella. Es una identidad sombra: presente, sincronizada, pero no soberana.

## 2.4 El problema de la duplicación

Esta arquitectura significa:

- Dos almacenes de credenciales (Auth0 + PDS)
- Dos espacios de nombres de handles (handles de AC + handles de PDS)
- Dos rutas de sincronización (los cambios de handle se propagan Auth0 → MongoDB → PDS)
- Una dependencia de pago (suscripción a Auth0)
- Sin interoperabilidad (un usuario de Bluesky no puede iniciar sesión en AC con su identidad existente)

El PDS ya sabe quién es cada usuario. Ya almacena su DID, su handle, su contenido. La capa de Auth0 añade coste y complejidad sin añadir capacidad que el PDS no pueda proporcionar.

## 3. LA PILA DE IDENTIDAD DEL AT PROTOCOL

Comprender la migración requiere comprender las tres capas de identidad de AT Protocol: DIDs, handles y OAuth.

### 3.1 Identificadores descentralizados (DIDs)

Un DID [W3C, 2022, Bluesky PBC, 2024b] es un identificador persistente y criptográficamente verificable. AT Protocol utiliza principalmente did:plc, un método diseñado para consistencia fuerte, alta disponibilidad y rotación de claves sin pérdida de identidad. Cada DID se resuelve a un documento que contiene:

- Una **clave de firma** (P-256 o K-256) [Bluesky PBC, 2024a] para autenticar actualizaciones del repositorio
- **Claves de rotación** para recuperación de cuenta
- Una URL de **endpoint PDS**
- El **handle** actual del usuario

El DID es la identidad estable. Los handles cambian; las claves rotan; los proveedores de PDS van y vienen. El DID persiste. AC ya acuña DIDs para cada usuario a través de su PDS. La infraestructura existe.

### 3.2 Verificación de handles

Un handle de AT Protocol [Bluesky PBC, 2024c] es un nombre de dominio que se resuelve bidireccionalmente a un DID. La verificación utiliza dos métodos:

**DNS TXT:** Colocar un registro en \_atproto.example.com:

```
_atproto.example.com TXT "did=did:plc:abc..."
```

**HTTPS Well-Known:** Servir el DID en:

```
GET /.well-known/atproto-did
Response: did:plc:abc...
```

Ambos métodos requieren que el handle se resuelva al DID y que el documento DID reclame el handle de vuelta. Esta verificación bidireccional significa: si controlas el dominio, controlas el handle. Ninguna autoridad central asigna handles; el DNS es la autoridad.

Para AC, esto significa que jeffrey.at.aesthetic.computer es un handle ATProto real y verificable porque AC controla tanto el DNS como el PDS. Pero también significa que un usuario que ya posee alice.bsky.social o alice.dev tiene una identidad criptográficamente verificada en la que AC puede confiar sin una contraseña.

### 3.3 ATProto OAuth

La especificación OAuth de AT Protocol [Bluesky PBC, 2024d] extiende OAuth 2.1 con tres mecanismos

de seguridad obligatorios:

**PKCE** (Proof Key for Code Exchange) [Sakimura et al., 2015]: Previene la interceptación de códigos de autorización. El cliente genera un verificador aleatorio, envía su hash con la solicitud de autorización y demuestra posesión del verificador original durante el intercambio de tokens.

**PAR** (Pushed Authorization Requests) [Lodderstedt et al., 2021]: El cliente envía los parámetros de autorización mediante POST al servidor de autorización *antes* de redirigir al usuario. Esto previene la manipulación de parámetros en la URL de redirección.

**DPoP** (Demonstrating Proof of Possession) [Fett et al., 2023]: Cada solicitud incluye un JWT firmado que demuestra que el cliente posee la clave privada asociada al token. Incluso si un access token se filtra, no puede ser utilizado por otro cliente.

### 3.3.1 Identificación del cliente

A diferencia del OAuth tradicional, AT Protocol no requiere prerregistro con cada servidor de autorización. En su lugar, los clientes publican metadatos en una URL HTTPS pública:

```
// aesthetic.computer/oauth/client-metadata.json
{
  "client_id": "https://aesthetic.computer/...",
  "client_name": "Aesthetic Computer",
  "redirect_uris": ["https://..."],
  "grant_types": ["authorization_code"],
  "dpop_bound_access_tokens": true
}
```

Cualquier PDS puede descubrir y verificar el cliente obteniendo esta URL. Sin secretos precompartidos, sin registro en tiendas de aplicaciones, sin gestión de claves API.

### 3.3.2 El flujo

1. El usuario introduce su handle (p. ej., `alice.bsky.social`)
2. El cliente resuelve handle → DID → endpoint PDS → servidor de autorización
3. El cliente envía los parámetros de autorización mediante PAR
4. El usuario es redirigido a la UI de autorización de su PDS
5. El usuario aprueba; el PDS redirige de vuelta con el código de autorización
6. El cliente intercambia el código por un access token vinculado con DPoP
7. El cliente verifica que el DID devuelto coincide con la identidad esperada

La diferencia crítica respecto a Auth0: el usuario se autentica con *su propio servidor*. AC nunca ve una con-

traseña. El PDS—ya sea el de Bluesky, el propio de AC o una instancia autoalojada—es la autoridad de identidad.

## 4. CASO DE ESTUDIO: PKT.BLOG

`pckt.blog` [pckt.blog, 2025] es una plataforma de blogging que autentica exclusivamente a través de AT Protocol OAuth. Su implementación demuestra la viabilidad práctica de la autenticación solo-ATProto para una plataforma de contenido.

### 4.1 Autenticación

Los usuarios inician sesión introduciendo su handle ATProto. `pckt.blog` resuelve el handle, descubre el servidor de autorización e inicia el flujo OAuth. El usuario aprueba en su PDS (Bluesky, Blacksky, un servidor autoalojado). `pckt.blog` recibe un access token vinculado con DPoP y el DID del usuario. No se almacenan contraseñas. No se mantiene una base de datos de usuarios separada.

### 4.2 Soberanía de datos

El contenido se sincroniza con el PDS del propio usuario utilizando lexicons de Standard.site [Standard.site, 2025]:

- `site.standard.publication` — colecciones de blog
- `site.standard.document` — artículos individuales
- `site.standard.graph.subscription` — relaciones de seguimiento

Si `pckt.blog` desaparece, el contenido del usuario permanece en su PDS, accesible para cualquier lector compatible. Esta es la promesa de ATProto: la plataforma es una vista, no un silo.

### 4.3 Implicaciones para AC

`pckt.blog` demuestra que una plataforma orientada al contenido puede operar enteramente sobre identidad ATProto. Los paralelismos con AC son directos:

- `pckt.blog` publica artículos; AC publica piezas, pinturas y estados de ánimo
- `pckt.blog` usa lexicons de Standard.site; AC tiene seis lexicons personalizados `computer.aesthetic.*`
- Los usuarios de `pckt.blog` poseen su contenido en su PDS; AC ya replica contenido en su PDS
- Ambas son aplicaciones Node.js/JavaScript

La brecha: `pckt.blog` fue construido nativo de ATProto. AC tiene una base de usuarios Auth0 existente que debe migrarse elegantemente.

## 5. MIGRACIÓN PROPUESTA

### 5.1 Fase 1: ATPProto OAuth como inicio de sesión secundario

Añadir “Iniciar sesión con Bluesky” junto a Auth0, sin eliminar Auth0.

#### Infraestructura:

1. Publicar metadatos del cliente en `aesthetic.computer/oauth/client-metadata.json`
2. Añadir `@atproto/oauth-client-node` [Bluesky PBC, 2024f] al backend
3. Crear dos nuevas funciones Netlify:
  - `POST /api/atproto-auth/start` — resolver handle, PAR, redirigir
  - `GET /api/atproto-auth/callback` — intercambio de código con DPoP
4. Almacenar sesiones en Redis (DID, handle, par de claves DPoP, tokens)

**Flujo del cliente:** Un nuevo botón “Iniciar sesión con Bluesky” en `boot.mjs` activa el flujo ATPProto OAuth. En caso de éxito, `window.acUSER` se llena desde la sesión ATPProto (DID como sub, handle, sin correo electrónico a menos que el usuario lo proporcione). La superficie de la API de piezas es idéntica—las piezas ven un usuario con un handle, independientemente de qué ruta de autenticación creó la sesión.

### 5.2 Fase 2: Puente de handles

Cuando un usuario inicia sesión mediante ATPProto, crear un puente para su handle hacia AC:

1. Extraer el nombre de usuario del handle ATPProto (p. ej., `alice` de `alice.bsky.social`)
2. Verificar disponibilidad contra la colección `@handles` de AC
3. Si está disponible y es válido (1–16 caracteres, alfanumérico), ofrecer reclamación con un clic
4. Si está ocupado, verificar si el correo del propietario existente coincide—ofrecer vinculación de cuentas
5. Si está ocupado por otra persona, solicitar una alternativa
6. Almacenar un mapeo `DID ↔ AC sub` en MongoDB para futuros inicios de sesión

Los handles de dominio personalizado (p. ej., `alice.dev`) requieren que el usuario elija manualmente un handle de AC, ya que el dominio en sí puede no corresponder a una cadena de handle válida.

### 5.3 Fase 3: Vinculación de identidad

Los usuarios existentes de Auth0 pueden vincular su identidad ATPProto:

1. Desde la configuración de la cuenta, iniciar ATPProto OAuth
2. En caso de éxito, almacenar el DID externo junto al sub de Auth0
3. Los futuros inicios de sesión aceptan ambas rutas de

autenticación

4. El contenido puede sincronizarse opcionalmente con el PDS externo del usuario (no solo con el PDS de AC)

Esta fase transforma el campo existente `users.atproto` de una identidad sombra a un vínculo de identidad de primera clase.

### 5.4 Fase 4: ATPProto-primario

Una vez validada la migración:

1. Los nuevos registros utilizan ATPProto OAuth por defecto (creando cuentas en el PDS de AC)
2. Auth0 permanece como ruta legacy para usuarios existentes
3. Descontinuación gradual de Auth0 a medida que los usuarios vinculan sus identidades ATPProto
4. Eliminar la dependencia de Auth0, eliminar el coste de suscripción

### 5.5 Enrutamiento de PDS

Una decisión arquitectónica clave: ¿a dónde va el contenido?

- **Usuarios solo-Auth0:** el contenido se sincroniza con el PDS de AC (comportamiento actual)
- **Usuarios ATPProto con PDS externo:** el contenido se sincroniza con su PDS
- **Usuarios ATPProto en el PDS de AC:** el contenido permanece en el PDS de AC

Esto significa que las funciones de sincronización del backend (`media-atproto.mjs`, `painting-atproto.mjs`, etc.) necesitan una ruta condicional: resolver el endpoint PDS del usuario desde su documento DID y escribir en ese endpoint en lugar de asumir el PDS de AC.

## 6. SEMÁNTICA DE HANDLES

El handle es la parte más visible para los humanos de la pila de identidad, y la migración plantea preguntas sobre lo que un handle *significa*.

### 6.1 Modelo de handle actual

Hoy, un handle de AC es:

- Una cadena de 1–16 caracteres, por orden de llegada
- Único dentro del espacio de nombres de AC
- Usado para URLs (`@alice/painting`), chat y personalización del OS
- Almacenado en MongoDB, cacheado en Redis
- Replicado en el PDS como `alice.at.aesthetic.computer`

### 6.2 Modelo de handle ATPProto

Un handle ATPProto es:

- Un nombre de dominio (cualquier nombre DNS válido)
- Verificado bidireccionalmente contra un DID



- Globalmente único por autoridad DNS
- Portátil entre servicios

### 6.3 Puente entre los modelos

La propuesta: un handle de AC es un *alias* que mapea a un DID. La fuente de verdad se desplaza de MongoDB a la capa DID. Múltiples métodos de inicio de sesión (Auth0, ATPProto OAuth) se resuelven al mismo DID, que se resuelve al mismo handle de AC.

Para AC Native OS [Jeffrey, 2026], donde el handle está inscrito en `config.json` en la partición de arranque, esto significa que la identidad del dispositivo está respaldada por una identidad criptográfica. “Hola @alice” en la pantalla de arranque significa el DID de Alice, la clave de firma de Alice, la identidad portátil de Alice—no solo una cadena en un archivo de configuración.

## 7. PREGUNTAS ABIERTAS

**Prioridad de handles.** Si `alice` no está reclamado en AC pero `alice.bsky.social` inicia sesión, ¿debería obtenerlo automáticamente? El orden de llegada es simple pero permite el acaparamiento. La prioridad verificada por ATPProto es más justa pero añade complejidad.

**Requisito de correo electrónico.** Auth0 proporciona correo electrónico verificado para recuperación de cuentas. ATPProto OAuth no garantiza correo electrónico. ¿Debería AC requerir un correo electrónico para funcionalidades completas de la cuenta (compras, notificaciones)?

**Multi-tenant.** AC opera un segundo tenant (`sotce`) con Auth0 separado. ¿Cómo se mapean las identidades ATPProto entre tenants? El DID es agnóstico al tenant, lo que puede simplificar la identidad entre tenants.

**Servidor de sesiones.** Las funcionalidades en tiempo real (chat, multijugador) se autentican mediante tokens Auth0 reenviados a través de WebSocket. El servidor de sesiones debe aceptar tokens emitidos por ATPProto o un token de sesión unificado.

**Emparejamiento de dispositivos.** AC Native OS empareja mediante un código de 6 caracteres intercambiado a través de Auth0. El equivalente en ATPProto: escanear un código QR que inicia un flujo OAuth en el teléfono, entregando tokens al dispositivo.

**Identidad de administrador.** El administrador actualmente es `handle === "jeffrey" && sub === ADMIN_SUB`. Bajo autenticación ATPProto-first, el administrador es `did === admin_did`—más limpio, fundamentado criptográficamente.

## 8. TRABAJO RELACIONADO

**Identidad descentralizada.** La especificación DID del W3C [W3C, 2022] proporciona el marco formal para identificadores descentralizados. El método `did:plc` del AT Protocol [Bluesky PBC, 2024b] lo extiende con garan-

tías de consistencia fuerte y un directorio centralizado-pero-auditable en `plc.directory`. Este es un compromiso pragmático: la descentralización completa de la resolución de identidad sigue siendo un problema abierto, y `did:plc` intercambia algo de descentralización por fiabilidad operativa.

**Aplicaciones nativas de ATPProto.** `pckt.blog` [pckt.blog, 2025] demuestra el blogging; `Leaflet.pub` y `Offprint.app` colaboran en lexicons compartidos a través de `Standard.site` [Standard.site, 2025]. Estas aplicaciones demuestran la viabilidad de la autenticación solo-ATProto para plataformas de contenido.

**Seguridad OAuth.** DPOP [Fett et al., 2023] previene el robo de tokens; PAR [Lodderstedt et al., 2021] previene la manipulación de parámetros; PKCE [Sakimura et al., 2015] previene la interceptación de códigos. Juntos representan el estado del arte en seguridad OAuth basada en navegador—significativamente más fuerte que el flujo Auth0 SPA que AC utiliza actualmente.

**Identidad convivial.** Las herramientas para la convivialidad de Illich [Illich, 1973] enmarcan la pregunta: ¿el sistema de identidad expande la autonomía personal, o requiere dependencia de un proveedor? Auth0 es un servicio administrado—conveniente pero dependiente. La identidad ATPProto es portátil, autoverificable e independiente del proveedor. La visión de Nelson de la computación personal [Nelson, 1974] se extiende naturalmente a la identidad personal: deberías ser dueño de tu nombre en la red.

## 9. CONCLUSIÓN

Aesthetic Computer ya ejecuta un PDS, acuña DIDs, sincroniza contenido con registros ATPProto y publica lexicons personalizados. La única pieza que falta es permitir que los usuarios se autenticuen a través de esa infraestructura en lugar de pasar por Auth0. La migración no es una reescritura—es la eliminación de un parche.

El enfoque por fases (ATProto como inicio de sesión secundario → puente de handles → vinculación de identidad → ATPProto-primario) asegura que ningún usuario existente sea perturbado. El estado final: una plataforma de computación creativa donde tu handle es una identidad criptográfica, tu contenido vive en un servidor que tú controlas, e iniciar sesión significa demostrar que posees tus claves—no confiar en un tercero para que responda por ti.

El PDS ya está funcionando. Los DIDs ya están acuñados. Los lexicons ya están publicados. Es hora de dejar que los usuarios inicien sesión por la puerta principal.

### Enlaces de referencia

#### Especificaciones del AT Protocol:

- <https://atproto.com/specs> — Especificación completa del

protocolo

- <https://atproto.com/specs/oauth> — Especificación OAuth
- <https://atproto.com/specs/handle> — Resolución de handles
- <https://atproto.com/specs/cryptography> — Métodos criptográficos
- <https://web.plc.directory/spec/v0.1/did-plc> — Especificación DID PLC
- <https://atproto.com/guides/lexicon> — Sistema de esquemas Lexicon
- <https://atproto.com/guides/oauth-patterns> — Patrones de implementación OAuth

#### Guías de implementación:

- <https://docs.bsky.app/blog/oauth-atproto> — Construir aplicaciones ATPROTO OAuth
- <https://docs.bsky.app/docs/advanced-guides/resolving-identities> — Resolución de identidades
- <https://docs.bsky.app/docs/advanced-guides/oauth-client> — Guía del cliente OAuth

#### Paquetes NPM:

- @atproto/oauth-client-node — Cliente OAuth para Node.js
- @atproto/oauth-client-browser — Cliente OAuth para navegador
- @atproto/api — Cliente TypeScript XRPC
- @atproto/identity — Resolución de DID/handle
- @atproto/oauth-browser-client — Alternativa ligera

#### Implementaciones de referencia:

- <https://github.com/pilcrowonpaper/atproto-oauth-example> — Ejemplo OAuth con Astro
- <https://github.com/bluesky-social/atproto> — Monorepo oficial de ATPROTO
- <https://standard.site/docs/introduction/> — Lexicons compartidos de Standard.site

#### Aplicaciones que usan ATPROTO Auth:

- pkt.blog — Blogging en la web social abierta
- Leaflet.pub — Publicación de formato largo
- Offprint.app — Escritura colaborativa

#### Estándares IETF:

- RFC 9449 — DPoP (Demonstrating Proof of Possession)
- RFC 7636 — PKCE (Proof Key for Code Exchange)
- RFC 9126 — PAR (Pushed Authorization Requests)

## References

Auth0 by Okta. Auth0 Single Page App SDK. <https://auth0.com/docs/libraries/auth0-single-page-app-sdk>, 2024. JavaScript SDK for browser-based OAuth flows.

Bluesky PBC. At protocol cryptography specification. <https://atproto.com/specs/cryptography>, 2024a. P-256 and K-256 elliptic curve signing.

Bluesky PBC. Did plc specification v0.1. <https://web.plc.directory/spec/v0.1/did-plc>, 2024b. Decentralized Identifiers for AT Protocol.

Bluesky PBC. At protocol handle specification. <https://atproto.com/specs/handle>, 2024c. Handle resolution via DNS TXT and HTTPS well-known.

Bluesky PBC. At protocol oauth specification. <https://atproto.com/specs/oauth>, 2024d. OAuth 2.1 with PKCE, DPoP, and PAR for decentralized authentication.

Bluesky PBC. At protocol specification. <https://atproto.com/specs>, 2024e. Decentralized social networking protocol.

Bluesky PBC. @atproto/oauth-client-node. <https://www.npmjs.com/package/@atproto/oauth-client-node>, 2024f. Node.js AT Protocol OAuth client library.

Daniel Fett, Brian Campbell, John Bradley, Torsten Lodderstedt, Michael Jones, and David Waite. RFC 9449: OAuth 2.0 Demonstrating Proof of Possession (DPoP). <https://datatracker.ietf.org/doc/html/rfc9449>, 2023. IETF standard for binding tokens to client key pairs.

Ivan Illich. *Tools for Conviviality*. Harper & Row, New York, 1973.

@jeffrey. Ac native os '26: A bare-metal creative computing operating system, 2026. Companion paper describing the AC Native OS.

Torsten Lodderstedt, Brian Campbell, Nat Sakimura, Dave Tonge, and Daniel Fett. RFC 9126: OAuth 2.0 Pushed Authorization Requests. <https://datatracker.ietf.org/doc/html/rfc9126>, 2021. Pushed Authorization Requests for OAuth.

Ted Nelson. *Computer Lib / Dream Machines*. Self-published, 1974. Revised edition 1987, Tempus Books/Microsoft Press.

pckt.blog. Blogging on the open social web and more exciting features. <https://devlog.pckt.blog/blogging-on-the-open-social-web-and-more-exciting-features-g9x55y6>, 2025. Development journal on ATPROTO blog integration.

Nat Sakimura, John Bradley, and Naveen Agarwal. RFC 7636: Proof Key for Code Exchange by OAuth Public Clients. <https://datatracker.ietf.org/doc/html/rfc7636>, 2015. PKCE for OAuth authorization code flow.

Standard.site. Standard site: Open blog publishing on at protocol. <https://standard.site/docs/introduction/>, 2025. Shared lexicons for blog content portability across ATPROTO.

W3C. Decentralized Identifiers (DIDs) v1.0. <https://www.w3.org/TR/did-core/>, 2022. W3C Recommendation for decentralized identifiers.